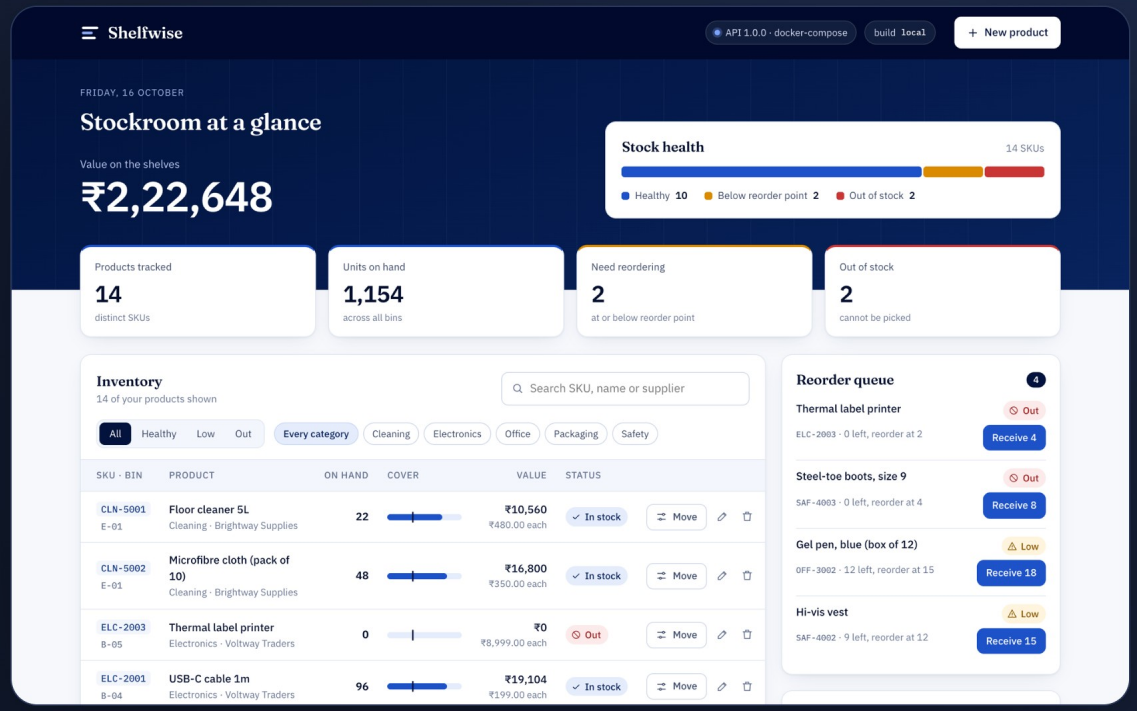
DEVOPS CAPSTONE · 2026

Shelfwise

From a laptop to a monitored Kubernetes cluster

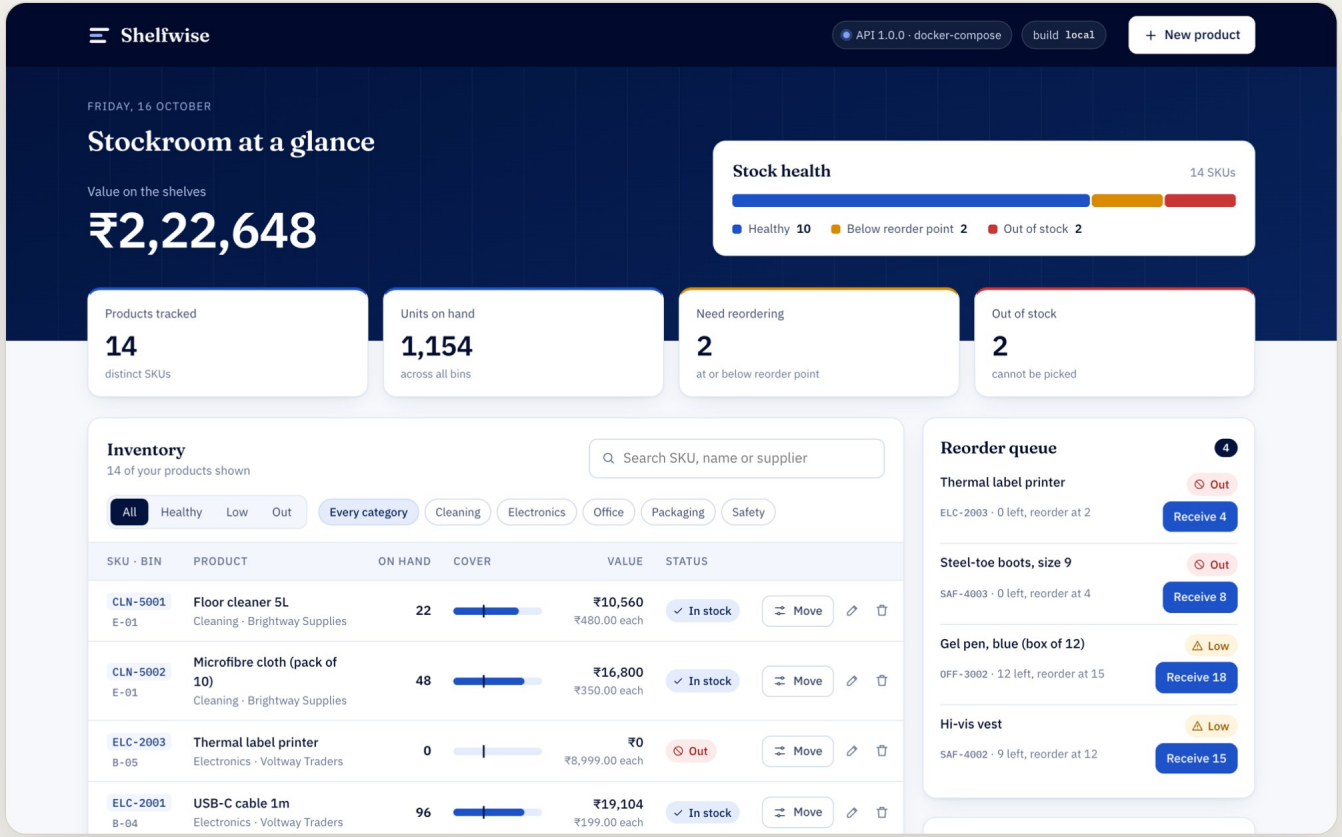
A small inventory app, and the whole delivery path around it: tests, containers, CI/CD with a security gate, Terraform, Helm, GitOps and observability.

Rashi Malik · github.com/RashiMalik02/shelfwise



M1 · THE APPLICATION

An inventory manager for a small stockroom



Products

SKU, bin location, supplier and unit price, with search and filters.

Reorder queue

Everything below its reorder point, one click to receive stock.

Stock ledger

Every movement logged. Picking more than exists returns 409.

`React 19 + Vite · FastAPI · PostgreSQL 17 · 11 REST endpoints`

WHAT'S IN IT

One small app, the whole delivery path

Frontend
React 19 + Vite on unprivileged nginx

Backend
FastAPI, SQLAlchemy 2, Pydantic

Database
PostgreSQL 17, Alembic migrations

Tests
29 pytest tests, ruff, node:test

Containers
Multi-stage, non-root images + Compose

CI/CD
GitHub Actions → Trivy → GHCR

Infrastructure
Terraform: VPC + EKS on AWS

Deployment
Helm: Ingress, HPA, PDBs, StatefulSet

GitOps
Argo CD syncs the chart; CI bumps the tag

Monitoring
Prometheus + Grafana, custom dashboard

Security
Restricted Pod Security, read-only root FS

Labs
Four break-and-fix troubleshooting labs

THE PATH

From git push to a running pod

Push
to main, or open a pull request

→

Test
ruff, pytest, node:test, helm lint, terraform test

→

Build
multi-stage Docker images

→

Scan
Trivy fails on HIGH or CRITICAL

→

Publish
GHCR, tagged with the commit SHA

`Deploy · DEPLOY_TARGET=eks`
helm upgrade straight onto the EKS cluster

`Deploy · GitOps`
CI commits the new SHA; Argo CD syncs the cluster

`Kubernetes · namespace shelfwise`
Traefik Ingress → nginx ×2 and FastAPI ×2–6 (HPA) → Postgres StatefulSet

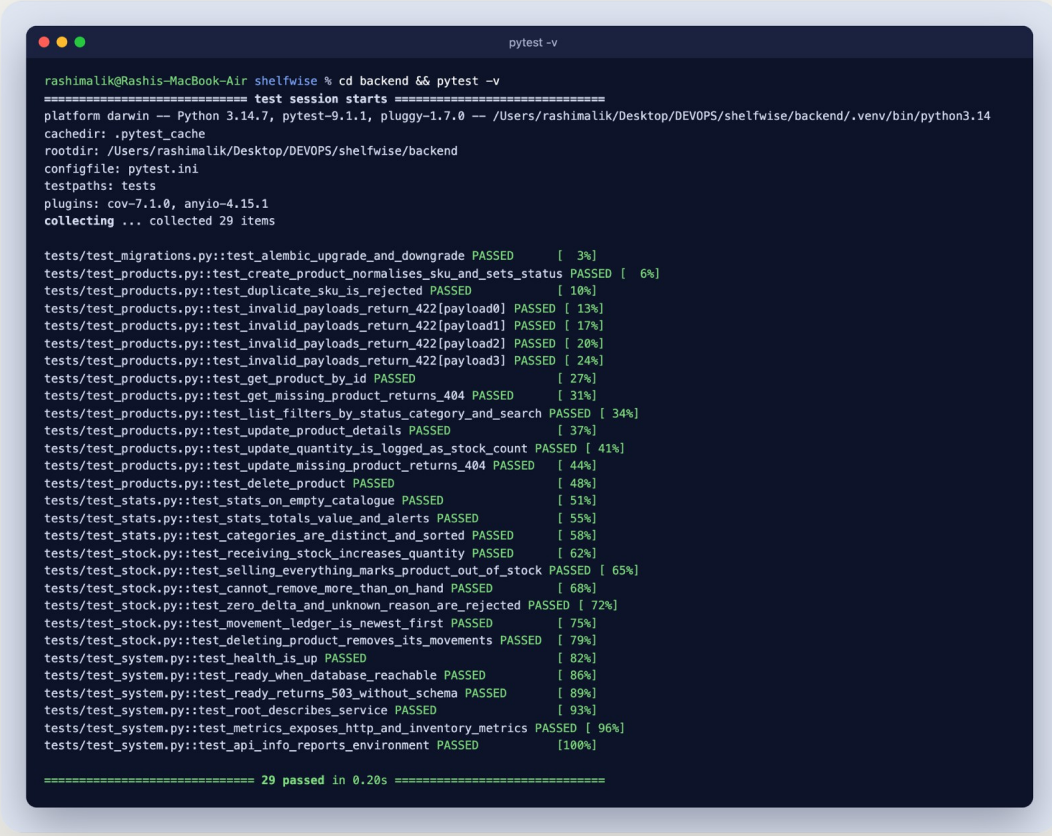
`Observability`
Prometheus scrapes every 15s → Grafana

M2 · TESTING

A failing test stops the pipeline

29 tests,
all passing

- Cover all 11 endpoints and the Alembic migration chain
- In-memory SQLite, never the real database
- ruff lint and format checks gate every push
- Frontend unit tests with node:test



M4 · DOCKER

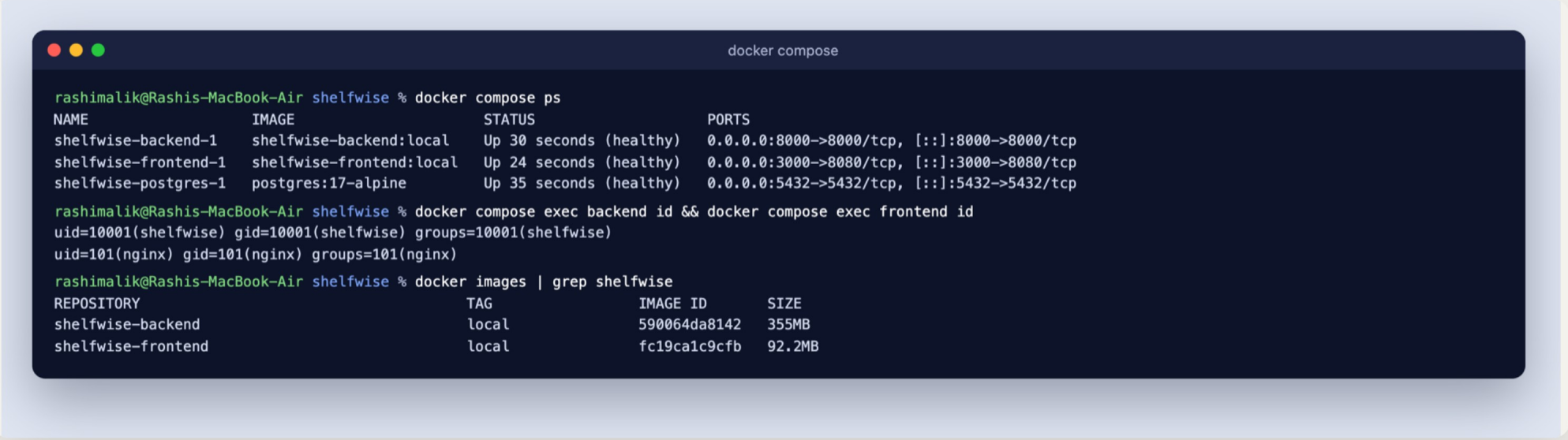
The whole stack in one command, nothing as root

3
services from docker compose up

2
stages: Node build → nginx runtime

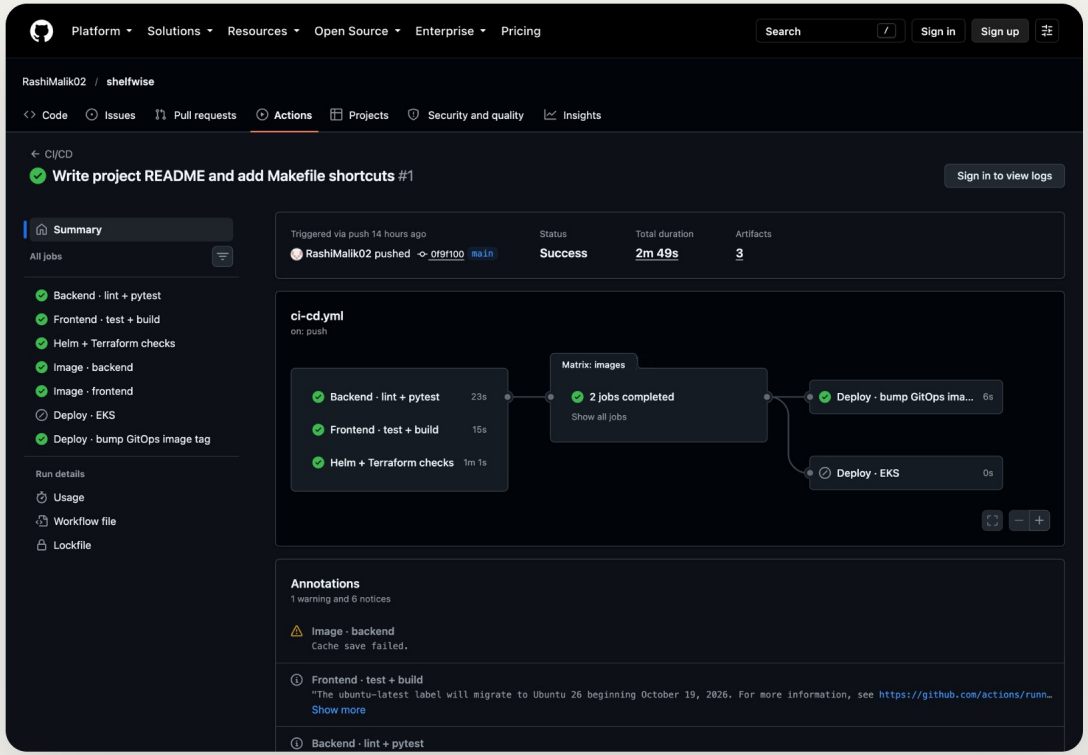
10001
backend user id, not root

101
nginx user id, not root

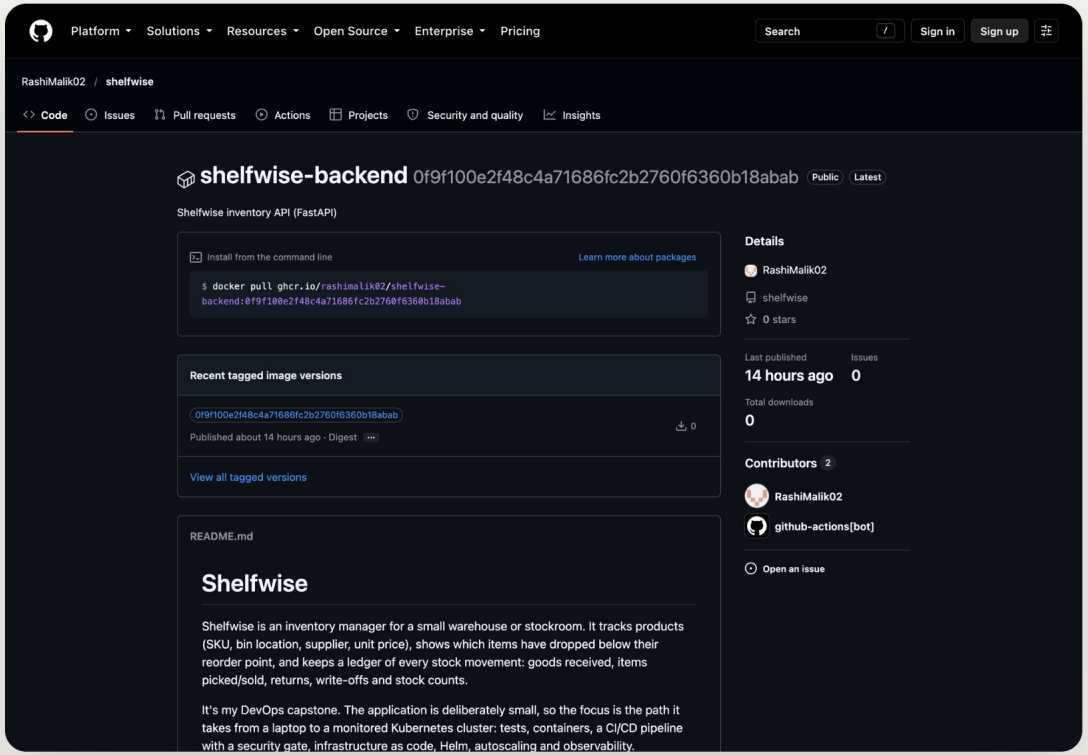


M5 · CI/CD

Every image traces back to one commit



Green run: test → build → scan → push → deploy

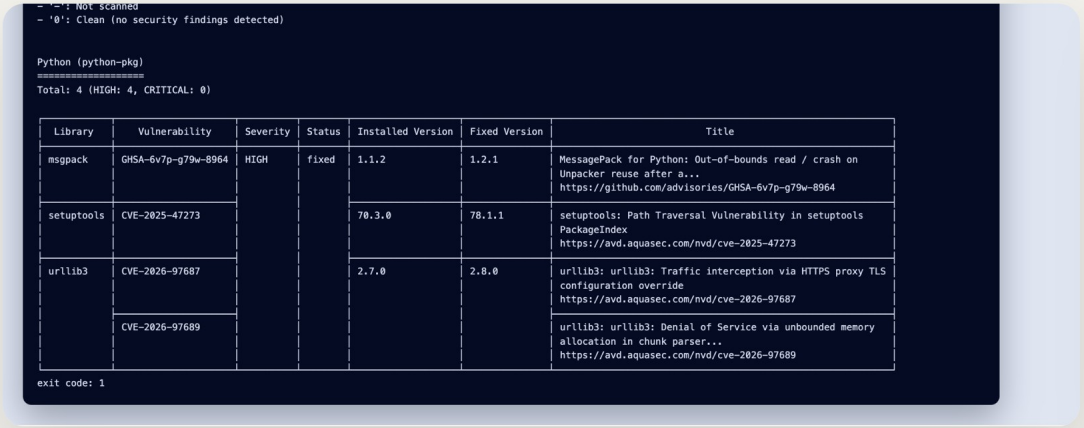


GHCR: tagged with the full commit SHA, never latest

M6 · SECURITY GATE

Trivy blocks the push on any fixable HIGH or CRITICAL

Before · 4 HIGH · exit 1

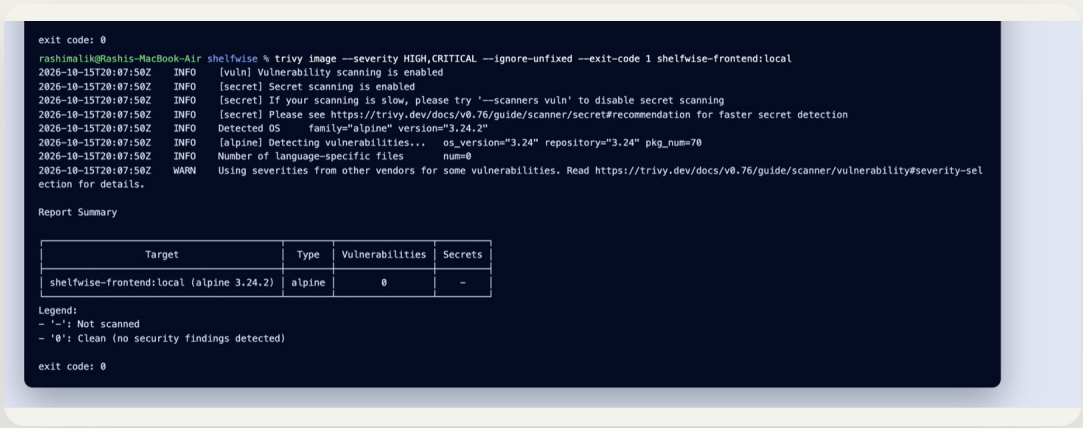


```
- '-': Not scanned
- '0': Clean (no security findings detected)

Python (python-pkg)
==================
Total: 4 (HIGH: 4, CRITICAL: 0)

┌──────────┬────────────────┬──────────┬────────┬───────────────────┬───────────────┬──────────────────────────────────────────────────────────────┐
│ Library  │ Vulnerability  │ Severity │ Status │ Installed Version │ Fixed Version │                            Title                             │
├──────────┼────────────────┼──────────┼────────┼───────────────────┼───────────────┼──────────────────────────────────────────────────────────────┤
│ msgpack  │ GHSA-6v7p-g79w-8964 │ HIGH │ fixed │ 1.1.2 │ 1.2.1 │ MessagePack for Python: Out-of-bounds read / crash on │
│          │                │          │        │                   │               │ Unpacker reuse after a...                                    │
│          │                │          │        │                   │               │ https://github.com/advisories/GHSA-6v7p-g79w-8964            │
├──────────┼────────────────┼──────────┼────────┼───────────────────┼───────────────┼──────────────────────────────────────────────────────────────┤
│ setuptools │ CVE-2025-47273 │          │        │ 70.3.0 │ 78.1.1 │ setuptools: Path Traversal Vulnerability in setuptools │
│          │                │          │        │                   │               │ PackageIndex                                                 │
│          │                │          │        │                   │               │ https://avd.aquasec.com/nvd/cve-2025-47273                   │
├──────────┼────────────────┼──────────┼────────┼───────────────────┼───────────────┼──────────────────────────────────────────────────────────────┤
│ urllib3  │ CVE-2026-97687 │          │        │ 2.7.0 │ 2.8.0 │ urllib3: urllib3: Traffic interception via HTTPS proxy TLS │
│          │                │          │        │                   │               │ configuration override                                       │
│          │                │          │        │                   │               │ https://avd.aquasec.com/nvd/cve-2026-97687                   │
│          ├────────────────┤          │        │                   │               ├──────────────────────────────────────────────────────────────┤
│          │ CVE-2026-97689 │          │        │                   │               │ urllib3: urllib3: Denial of Service via unbounded memory │
│          │                │          │        │                   │               │ allocation in chunk parser...                                │
│          │                │          │        │                   │               │ https://avd.aquasec.com/nvd/cve-2026-97689                   │
└──────────┴────────────────┴──────────┴────────┴───────────────────┴───────────────┴──────────────────────────────────────────────────────────────┘
exit code: 1
```

After · 0 findings · exit 0



```
exit code: 0
rashimalik@Rashis-MacBook-Air shelfwise % trivy image --severity HIGH,CRITICAL --ignore-unfixed --exit-code 1 shelfwise-frontend:local
2026-10-15T20:07:50Z    INFO    [vuln] Vulnerability scanning is enabled
2026-10-15T20:07:50Z    INFO    [secret] Secret scanning is enabled
2026-10-15T20:07:50Z    INFO    [secret] If your scanning is slow, please try '--scanners vuln' to disable secret scanning
2026-10-15T20:07:50Z    INFO    [secret] Please see https://trivy.dev/docs/v0.76/guide/scanner/secret#recommendation for faster secret detection
2026-10-15T20:07:50Z    INFO    Detected OS     family="alpine" version="3.24.2"
2026-10-15T20:07:50Z    INFO    [alpine] Detecting vulnerabilities...   os_version="3.24" repository="3.24" pkg_num=70
2026-10-15T20:07:50Z    INFO    Number of language-specific files       num=0
2026-10-15T20:07:50Z    WARN    Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.76/guide/scanner/vulnerability#severity-sel
ection for details.

Report Summary

┌──────────────────────────────────────┬────────┬─────────────────┬─────────┐
│                Target                │  Type  │ Vulnerabilities │ Secrets │
├──────────────────────────────────────┼────────┼─────────────────┼─────────┤
│ shelfwise-frontend:local (alpine 3.24.2) │ alpine │        0        │    -    │
└──────────────────────────────────────┴────────┴─────────────────┴─────────┘

Legend:
- '-': Not scanned
- '0': Clean (no security findings detected)

exit code: 0
```

The cause

All four came from copies of urllib3, msgpack and setuptools vendored inside pip, not from the app’s own dependencies.

The fix

The running API never needs pip, so it is removed from the runtime image. Both images now scan clean.

SUPPLY CHAIN

Tags can move.
Commit SHAs can’t.

Every third-party GitHub Action is pinned to a full commit SHA. In March 2026 attackers force-pushed almost every aquasecurity/trivy-action tag to a commit that stole CI secrets (CVE-2026-33634).

```
uses: aquasecurity/trivy-action@<40-char SHA> # v0.36.0
```

M7 · TERRAFORM ON AWS

A real VPC and EKS cluster, built and torn down

57
resources in the plan

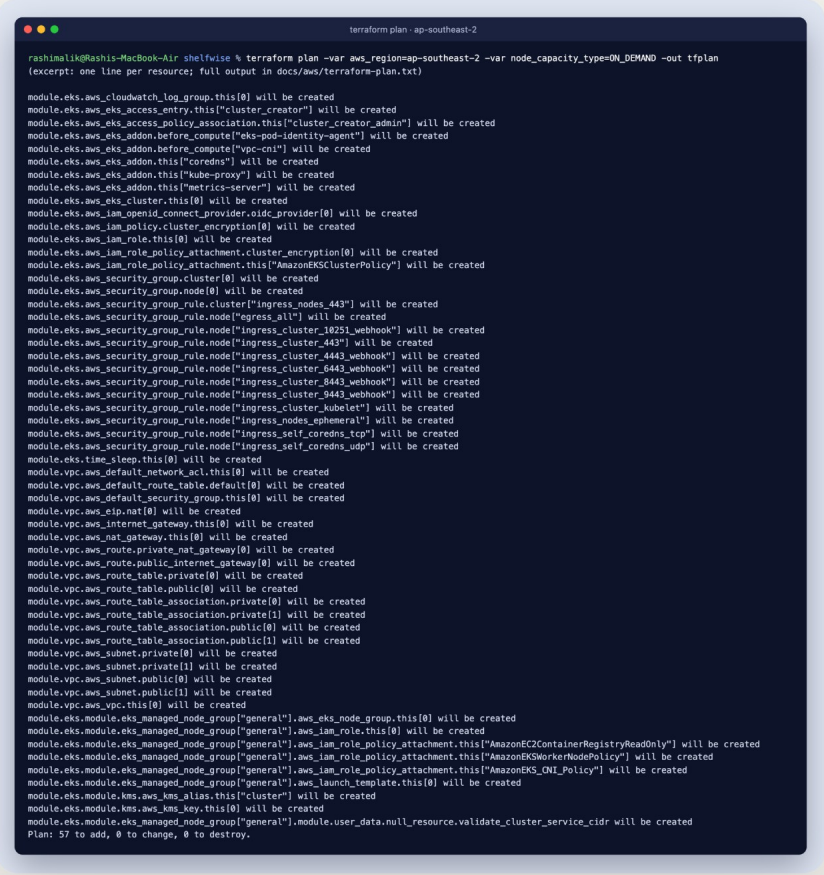
2 + 2
public + private subnets

56
destroyed, nothing left running

< $1
total cost of the run

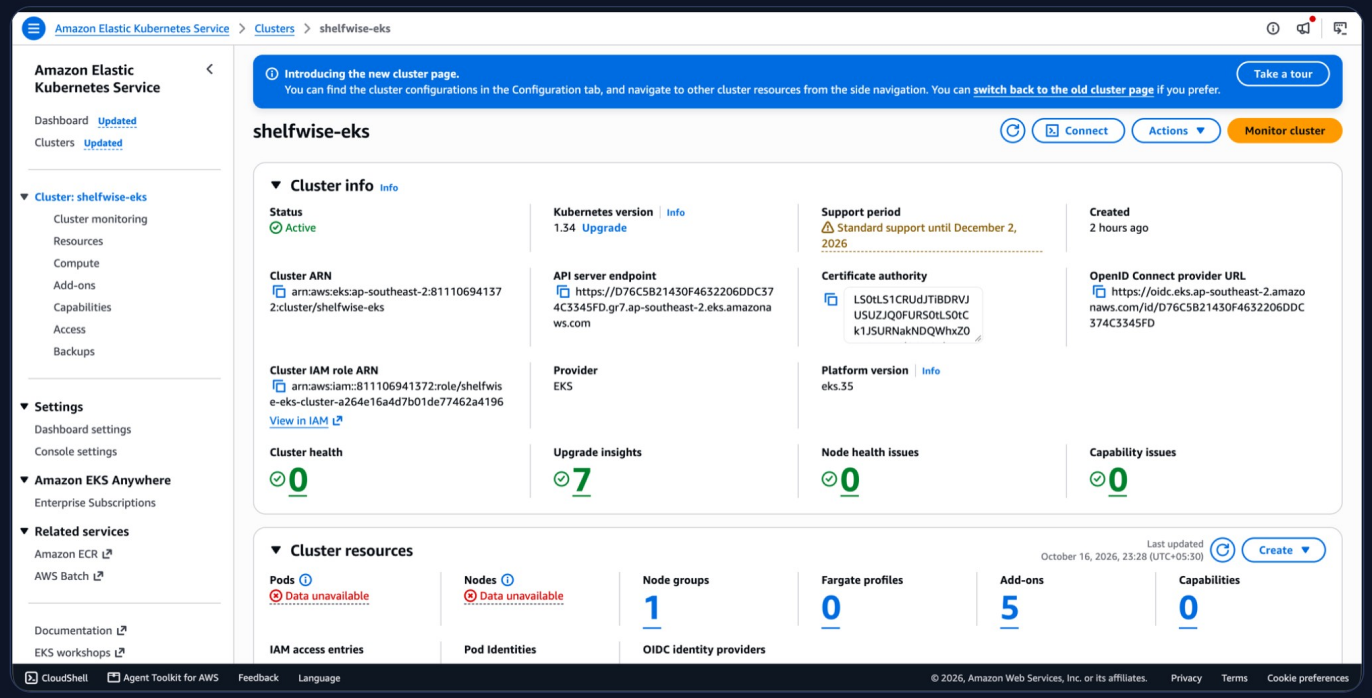
Free-plan AWS account

One region (ap-southeast-2), Free Tier nodes (c7i-flex.large), and Pod Identity instead of IRSA.

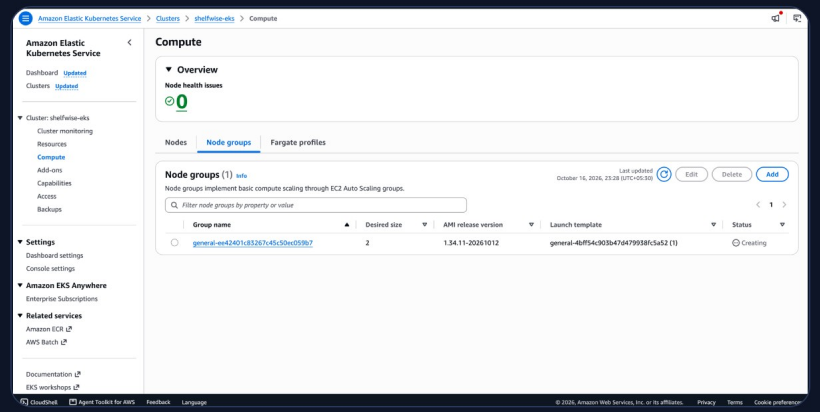


M7 · EVIDENCE IN THE AWS CONSOLE

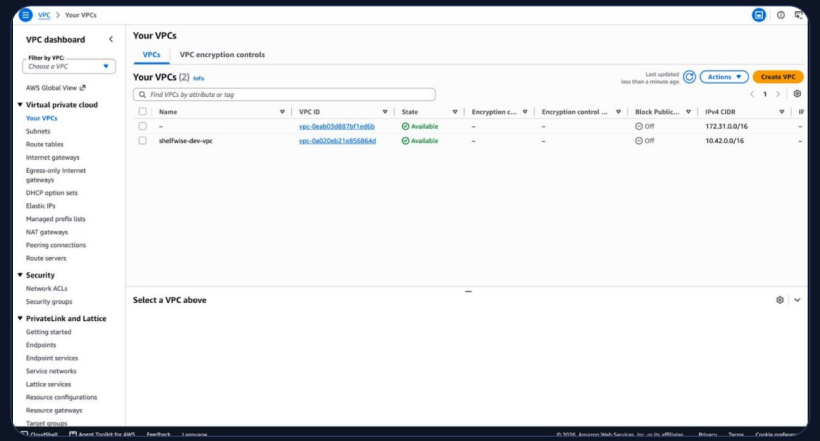
EKS cluster active, nodes ready, VPC in place



EKS cluster · Active · ap-southeast-2

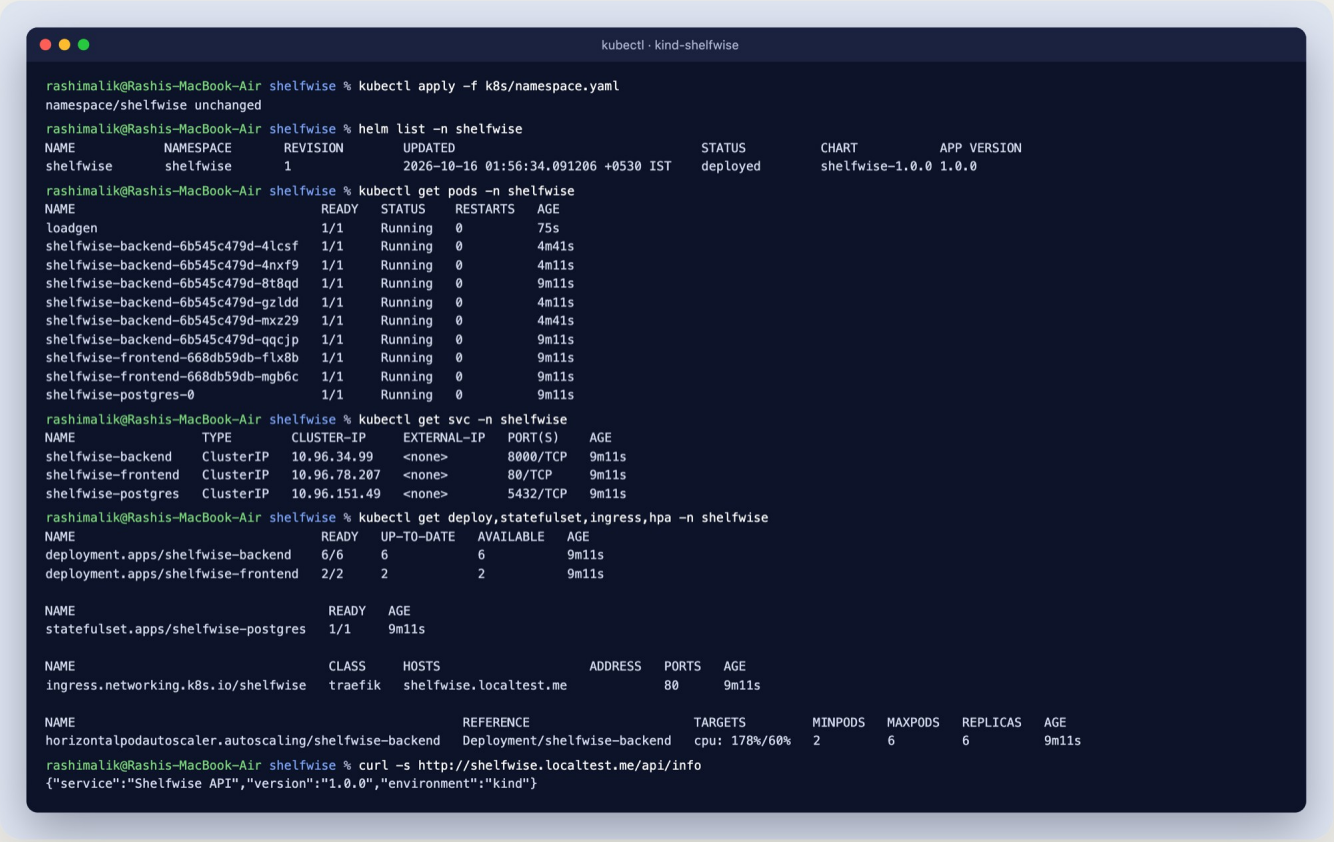


Managed node group



M8 · KUBERNETES + HELM

One Helm chart, from kind to EKS



Ingress (Traefik)

/ → frontend, /api and /docs → backend

Replicas + PDBs

2 of each; backend scales 2–6 with the HPA

Postgres StatefulSet

PVC-backed; password generated on install

/health and /ready

Liveness restarts; readiness only pulls the pod

`shelfwise.localtest.me`

M8 · AUTOSCALING

Under load, the backend scales itself

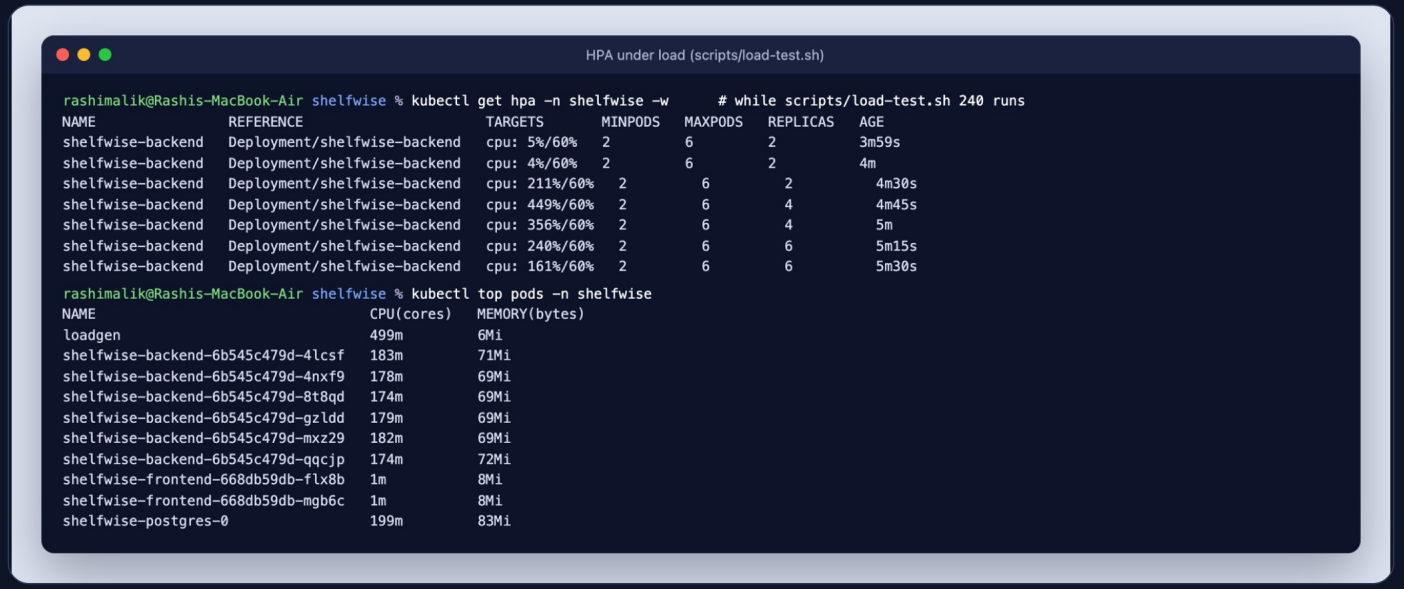
2 → 6

backend replicas

449%

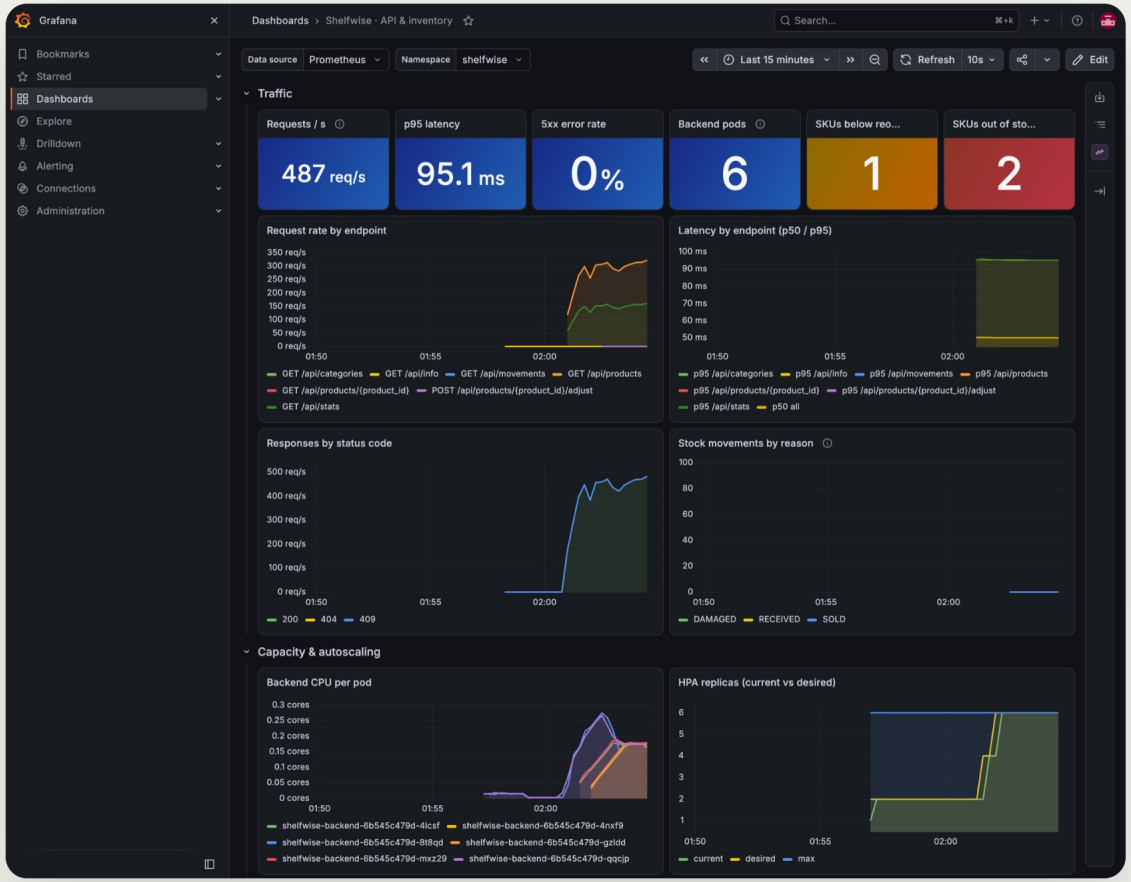
CPU at peak, up from 4% idle

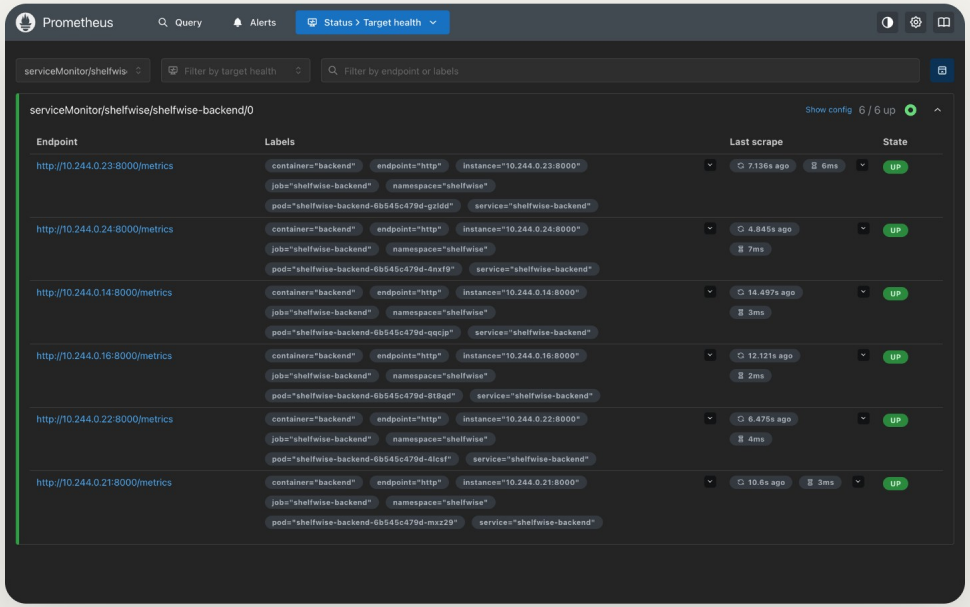
```
./scripts/load-test.sh 180
```



M9 · OBSERVABILITY

Live app and inventory metrics in Grafana



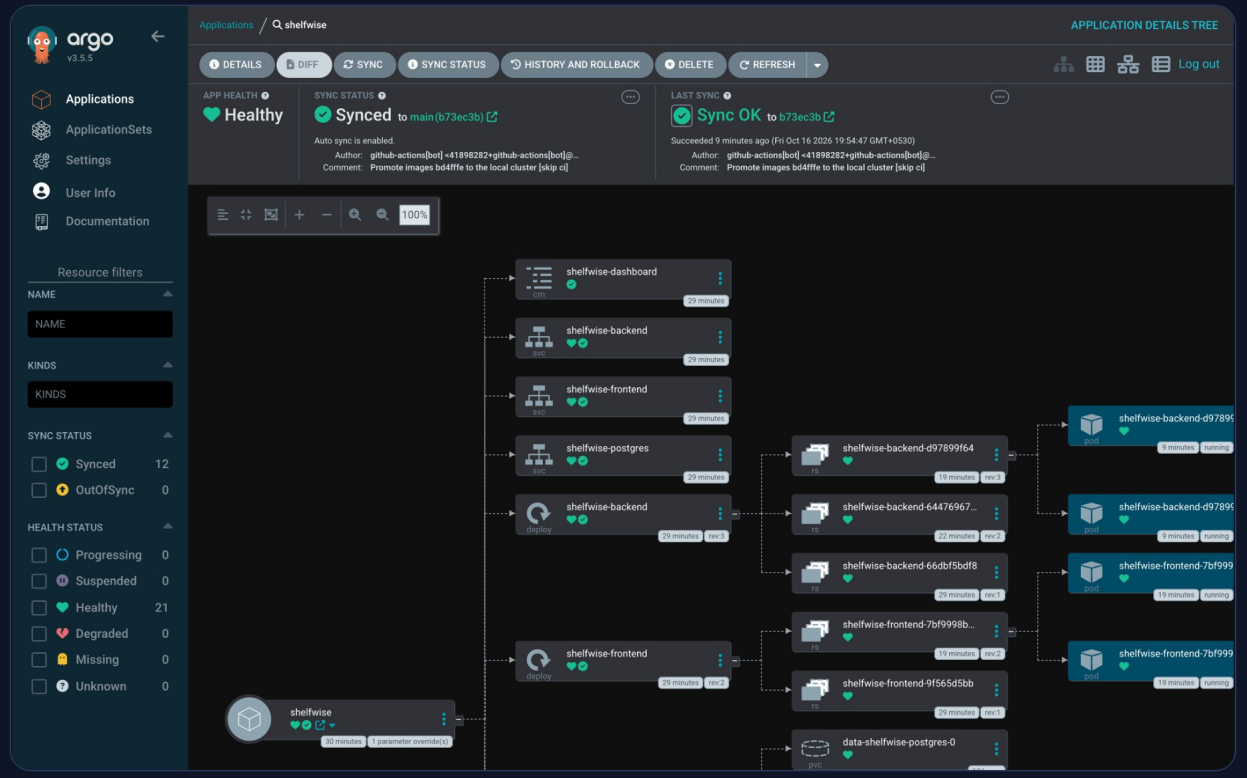


Prometheus: 6/6 backend pods UP, scraped every 15s

`shelfwise_stock_movements_total`
`shelfwise_units_on_hand`
`http_request_duration_seconds`

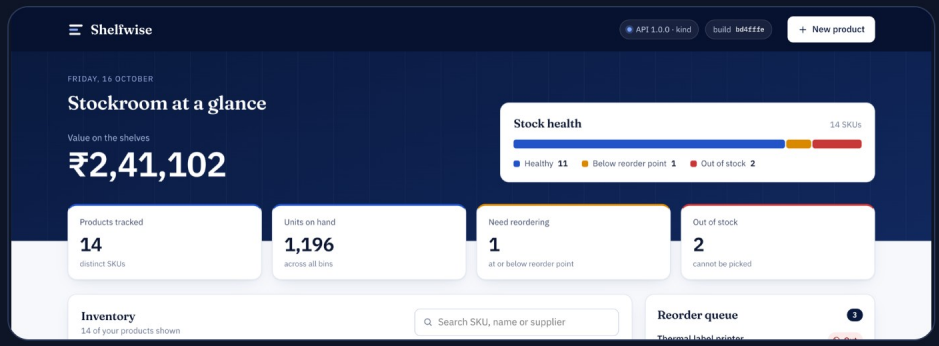
M10 · GITOPS

A commit becomes a deployment, untouched



Argo CD · Synced · Healthy

```
1 push bd4fffe
2 pipeline run green
3 bot commits b73ec3b
4 Argo CD syncs
5 pods roll to the new SHA
```



The header's build pill shows the SHA it was built from.

HARDENING

Secure by default, at every layer

Non-root images

Backend runs as uid 10001, nginx as uid 101.

Restricted Pod Security

The namespace enforces the strictest built-in standard.

Locked-down containers

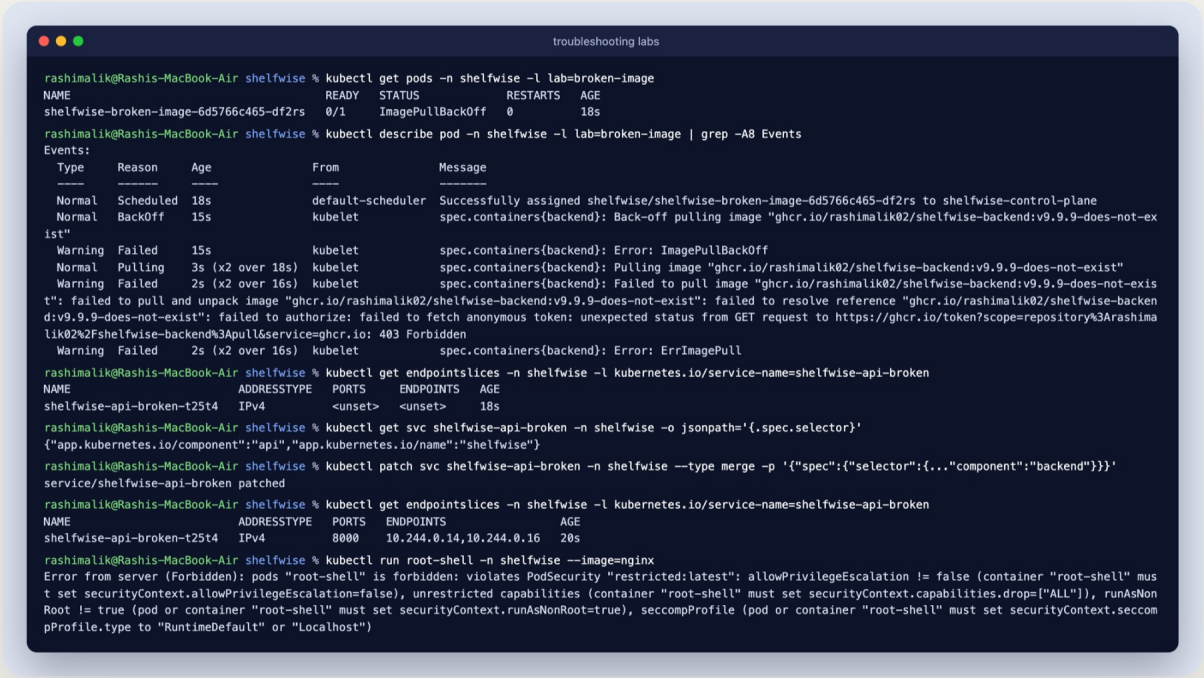
Read-only root filesystem, no privilege escalation, all capabilities dropped.

No committed secrets

Postgres password generated by the chart; tfvars and .env git-ignored.

M8 · TROUBLESHOOTING

Four labs: break it on purpose, then fix it



01 ImagePullBackOff
The image tag doesn’t exist

02 No endpoints
Service selector doesn’t match the pod labels

03 Running, not Ready
The database password is wrong

04 Forbidden
Pod Security Admission rejects the pod

DESIGN DECISIONS

The questions people ask

Why SHA tags, not latest?

Every pod traces back to an exact commit, and a rollback is just the previous SHA.

Why /health and /ready?

A database outage should pull the pod from the Service, not restart it.

Why Postgres in the cluster?

For the demo. On AWS I'd use RDS; the chart already takes an external database URL.

Why Traefik, not ingress-nginx?

ingress-nginx was archived in March 2026. Only ingressClassName changes.

SHELFWISE · DEVOPS CAPSTONE

Thank you

29 tests passing | 0 HIGH/CRITICAL CVEs | 57 AWS resources | 2 → 6 pods | < $1 cloud bill

Questions? · github.com/RashiMalik02/shelfwise